



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

MODUL PEMBELAJARAN

Pertemuan 4: Perencanaan dan Scoping Pengujian Penetrasi

Mata Kuliah Penetration Testing (KSI251522) — Semester 5

Mata Kuliah	Penetration Testing
Program Studi	Sarjana Terapan Keamanan Sistem Informasi, Politeknik Negeri Bengkalis
Dosen Pengampu	Nurmi Hidayasari
Sub-CPMK	01.2 — Mampu mengidentifikasi tujuan, komponen, prosedur, dan kriteria yang diperlukan untuk merencanakan pengujian penetrasi secara terkontrol.
Sifat Pengujian	Pengujian pada objek nyata dikerjakan mandiri oleh setiap mahasiswa — bukan tugas kelompok.
Alokasi Waktu	Teori: 1 x 50" Praktikum: 2 x 100" Tugas Mandiri (PT+KM): 1 x 120"

1. Capaian Pembelajaran

Indikator Capaian (sesuai RPS):

- Kelengkapan dokumen perencanaan pengujian (tujuan, ruang lingkup, target, batasan, jadwal, kriteria keberhasilan).
- Kesesuaian rencana dengan RoE dan tingkat risiko pengujian.

2. Pendahuluan

Pada Pertemuan 2, Anda telah menyusun dan menandatangani Rules of Engagement (RoE) untuk objek pengujian nyata — sebuah website hasil proyek mahasiswa yang sudah dipublikasikan namun belum digunakan oleh mitra. Pada Pertemuan 3, Anda mengenal PTES sebagai kerangka tujuh fase yang akan menjadi format kerja mata kuliah ini.

Modul ini menjembatani keduanya: bagaimana RoE (dokumen izin) dan PTES (kerangka tahapan) diterjemahkan menjadi satu dokumen perencanaan pengujian yang benar-benar Anda pakai untuk bekerja, minggu demi minggu, secara mandiri. Dokumen perencanaan ini bukan formalitas tambahan — ia adalah rencana kerja operasional yang akan menentukan apakah pengujian Anda berjalan terarah atau justru acak dan sulit dipertanggungjawabkan saat presentasi akhir.

Catatan penting: pengujian terhadap objek nyata pada mata kuliah ini dikerjakan secara mandiri oleh setiap mahasiswa. Dokumen perencanaan yang dibahas dalam modul ini adalah dokumen individu, disusun untuk objek nyata Anda sendiri, dan harus konsisten dengan RoE yang sudah ditandatangani.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

3. Uraian Materi

3.1 RoE dan Dokumen Perencanaan: Posisi dan Kaitannya

RoE menjawab pertanyaan “apa yang diizinkan?” Ia adalah dokumen hukum yang ditandatangani sekali di awal dan jarang dibuka kembali selama pengujian berlangsung. Dokumen perencanaan menjawab pertanyaan yang berbeda: “bagaimana izin itu dieksekusi menjadi pekerjaan sehari-hari?” — apa yang Anda kerjakan, kapan, dengan tools apa, dan bagaimana Anda mengukur bahwa pengujian sudah selesai.

Analogi sederhana: RoE adalah Surat Izin Mengemudi, dokumen perencanaan adalah rute perjalanan yang sudah dipetakan sebelum berangkat. Memiliki SIM tidak membuat Anda otomatis tahu jalan menuju tujuan — demikian pula RoE yang sah tidak membuat pengujian Anda otomatis terarah tanpa dokumen perencanaan.

Prinsip penting: dokumen perencanaan tidak pernah menciptakan otorisasi baru. Setiap bagian di dalamnya hanya mengoperasikan sesuatu yang sudah diizinkan RoE. Tabel berikut memetakan persis bagian RoE mana yang menjadi sumber tiap bagian dokumen perencanaan — gunakan ini sebagai referensi cepat saat mengisi dokumen Anda.

Bagian RoE	Isi	Dipakai di Dokumen Perencanaan
Bagian 3	Latar Belakang & Tujuan	Bagian 1 (Pre-engagement) — komponen Tujuan
Bagian 4	Ruang Lingkup	Bagian 1 — komponen Ruang Lingkup; juga membatasi checklist kategori WSTG di Bagian 4 (Vulnerability Analysis)
Bagian 5	Exclusion List	Bagian 1 — komponen Batasan; dirujuk ulang di Bagian 4 & 5 sebagai “tools yang tidak dipakai”
Bagian 6	Prosedur Eskalasi	Bagian 1 — komponen Kontak Eskalasi; menjadi dasar Kriteria Berhenti di Bagian 5 (Exploitation)
Bagian 8	Jadwal Pengujian	Bagian 1 — komponen Jadwal; dirinci lebih lanjut di Bagian 8 (Rencana Kerja Mingguan)

3.2 Enam Komponen Dokumen Perencanaan

1. Tujuan — apa yang ingin Anda buktikan atau temukan dari pengujian ini. Contoh: “mengidentifikasi kerentanan kategori OWASP Top 10 pada aplikasi X sebelum diserahkan kepada mitra.”

2. Ruang Lingkup — lapisan dan kategori pengujian yang tercakup, mengacu langsung pada Bagian 4 RoE. Untuk kasus mata kuliah ini, ruang lingkup dibatasi murni pada lapisan aplikasi web (HTTP/HTTPS).

3. Target — sistem/URL spesifik yang diuji, termasuk sub-domain atau fitur yang relevan. Target pada dokumen perencanaan harus identik dengan yang tertulis di RoE, tidak boleh lebih luas.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

4. Batasan — exclusion list operasional sehari-hari, diturunkan langsung dari RoE. Contoh: “tidak ada aktivitas Nmap atau pemindaian jaringan dalam bentuk apa pun, sepanjang semester.”

5. Jadwal — kapan tiap tahapan pengujian Anda kerjakan, disesuaikan dengan kalender 16 minggu perkuliahan, dan kapan tim pengembang perlu diberi tahu agar aktivitas di log mereka tidak menimbulkan kebingungan.

6. Kriteria Keberhasilan — definisi “selesai” yang Anda tetapkan sendiri. Contoh: seluruh kategori OWASP Top 10 yang relevan telah diuji dan dilaporkan, terlepas dari berapa banyak kerentanan yang ditemukan.

3.3 Manajemen Risiko Pengujian pada Target yang Sudah Live

Karena target adalah website yang sudah live — bukan mesin virtual di lab — setiap aktivitas pengujian membawa risiko nyata terhadap sistem, bukan sekadar risiko akademik. Risiko yang perlu dinilai antara lain: kemungkinan aplikasi menjadi lambat atau crash saat diuji, akun/data uji yang tertinggal di database produksi, dan risiko akun hosting terkena suspend jika aktivitas pengujian dianggap mencurigakan oleh sistem deteksi abuse penyedia hosting gratis (dibahas rinci di Pertemuan 2).

Mitigasi terbesar terhadap risiko ini sudah tertanam dalam desain semester secara keseluruhan: seluruh teknik yang berisiko tinggi terhadap ketersediaan sistem — pemindaian jaringan, brute force agresif — sudah dipindahkan seluruhnya ke lab dummy. Ini bukan mitigasi tambahan yang perlu Anda pikirkan sendiri, melainkan bagian dari scoping itu sendiri. Yang tetap menjadi tanggung jawab Anda untuk direncanakan: kapan akun/data uji dibuat dan dibersihkan, serta bagaimana melaporkan segera apabila pengujian Anda tanpa sengaja memengaruhi pengguna lain di sistem.

3.4 Kesesuaian Rencana dengan RoE

Indikator penilaian Pertemuan 4 secara eksplisit menilai “kesesuaian rencana dengan RoE” — bukan sekadar kelengkapan format dokumen. Dalam praktiknya, setiap kali Anda menulis komponen Ruang Lingkup atau Batasan, bukalah kembali RoE yang sudah ditandatangani dan kutip bagiannya secara langsung, bukan menuliskannya kembali dari ingatan.

Contoh ketidaksesuaian yang sering terjadi: dokumen perencanaan menyebut “akan mencoba Nmap ringan untuk memastikan port aman” — padahal RoE sudah melarang seluruh aktivitas pemindaian jaringan tanpa pengecualian. Jika rencana dan RoE ternyata berbeda, yang harus direvisi adalah **rencananya**, bukan meminta pengecualian RoE secara informal di tengah jalan.

3.5 Dua Jalur Pengujian: Target Nyata vs Lab Dummy

Karena Batasan pada RoE melarang seluruh aktivitas pemindaian jaringan terhadap target nyata, semester ini dirancang dengan dua jalur pengujian yang berjalan berdampingan. Dokumen perencanaan Anda wajib mencantumkan pemisahan ini secara eksplisit per minggu:

Mg	Lingkungan	Aktivitas
5	Kedua	OSINT pasif, WhatWeb/curl/DevTools → Real; ping/traceroute → Dummy
6	Dummy penuh	Nmap: host discovery, port scan, OS fingerprint — real target tidak disentuh



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

7	Kedua	OpenVAS/Nessus (full scan) → Dummy; Burp Suite/ZAP (HTTP-only) → Real
9	Kedua	Eksplorasi app-layer → Real (berhenti begitu dapat akses shell); kill-chain penuh → Dummy
10–12	Real	OWASP Top 10/WSTG: SQL Injection, XSS, autentikasi, kontrol akses
13	Kedua	Cek TLS/cipher (testssl.sh) → Real; baseline hardening & open port → Dummy

3.6 PTES sebagai Kerangka Kerja Tunggal

Mata kuliah ini menggunakan **PTES** sebagai kerangka kerja untuk seluruh dokumen kerja — dari dokumen perencanaan Pertemuan 4 ini hingga laporan akhir di Pertemuan 15. Ini adalah keputusan yang berlaku bagi seluruh kelas, bukan pilihan bebas antara PTES atau NIST SP 800-115 seperti yang mungkin terlihat memungkinkan dari perbandingan di Pertemuan 3.

Alasannya: tujuh fase PTES sudah mencakup seluruh siklus hidup engagement dalam satu struktur yang konsisten, sehingga dokumen kerja Anda tidak perlu menggabungkan dua kerangka berbeda. Konsekuensinya, mulai modul ini, istilah yang dipakai mengikuti penamaan PTES (Intelligence Gathering, Threat Modeling, dan seterusnya), bukan istilah NIST (Discovery, Attack). NIST SP 800-115 tetap relevan sebagai pengetahuan pembanding, dan dapat berguna kelak jika Anda bekerja di organisasi yang mewajibkan format audit federal — tetapi tidak dipakai sebagai format kerja pada mata kuliah ini.

3.7 Ketujuh Fase PTES Secara Detail

Bagian ini adalah inti dari modul: setiap fase PTES dijelaskan lengkap dengan apa yang dilakukan, hasil yang didapat, dan bagian mana persis di dokumen perencanaan yang harus diisi berdasarkan fase tersebut.

3.7.1 Pre-engagement Interactions

Fase yang menetapkan dasar hukum dan operasional seluruh engagement. Dalam mata kuliah ini, fase ini sudah selesai dikerjakan di Pertemuan 2 dalam bentuk RoE.

Apa yang Dilakukan:

- Menentukan tujuan pengujian bersama tim pengembang selaku pemberi izin.
- Menyepakati ruang lingkup, batasan (exclusion list), jadwal, dan kontak eskalasi.
- Menandatangani RoE.

Contoh Aktivitas Verifikasi: *fase ini tidak melibatkan pengujian teknis, tapi tetap ada yang perlu dicek konkret — mis. mencocokkan URL target di RoE (<https://contoh-app.polbeng.ac.id>) persis dengan yang akan diakses browser/tools, termasuk protokol (http vs https) dan ada-tidaknya redirect ke domain lain; serta mengonfirmasi ulang ke tim pengembang bahwa jadwal pengujian tidak berbenturan dengan kegiatan mereka.*

Hasil yang Didapat: Dokumen RoE yang sah dan ditandatangani — menjadi rujukan wajib bagi seluruh fase berikutnya.

Kaitan dengan Dokumen Perencanaan: Bagian 1 tidak ditulis dari nol — seluruh isinya dikutip langsung dari RoE (lihat tabel pemetaan pada 3.1). Tidak ada aktivitas baru di fase ini saat menyusun dokumen perencanaan, hanya proses kutip-ulang yang akurat.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

3.7.2 Intelligence Gathering

Reconnaissance pasif dan aktif terhadap target untuk membangun peta permukaan serangan sebelum pengujian teknis dimulai.

Apa yang Dilakukan:

- WHOIS dan pencarian registrasi domain.
- DNS lookup (dig/nslookup) dan Google dorking.
- Pemeriksaan header HTTP (curl -I/-v) dan deteksi teknologi (WhatWeb/Wappalyzer).
- Mencatat sumber informasi dan waktu pengumpulan.

Contoh Percobaan yang Bisa Dilakukan:

- `whois <domain>` — mengecek pemilik domain dan tanggal registrasi.
- `dig <domain> ANY` atau `nslookup -type=ANY <domain>` — mencari record DNS dan kemungkinan subdomain.
- `curl -I https://<domain>` — membaca header respons, mis. *Server: Apache/2.4.41, X-Powered-By: PHP/7.4*.
- Google dork `site:<domain> filetype:pdf OR filetype:xlsx` — mencari dokumen yang mungkin tidak sengaja terekspos publik.
- Menjalankan WhatWeb/Wappalyzer pada halaman utama untuk mendeteksi CMS, framework, atau library JavaScript yang dipakai.

Hasil yang Didapat: Peta awal permukaan serangan aplikasi — daftar teknologi yang dipakai, struktur URL/endpoint yang teridentifikasi, dan informasi kontak/organisasi yang relevan.

Kaitan dengan Dokumen Perencanaan: Mengisi Bagian 2 — daftar teknik OSINT yang direncanakan, sumber data yang ditargetkan, dan estimasi waktu. Karena RoE melarang pemindaian jaringan, seluruh teknik di sini harus murni berbasis HTTP/publik, tidak menyentuh port di luar 80/443.

3.7.3 Threat Modeling

Analisis untuk menentukan aset/fitur mana yang paling bernilai atau berisiko, agar pengujian berikutnya terarah dan tidak asal urut. Fase ini murni analisis — tidak memerlukan aktivitas teknis terhadap target.

Apa yang Dilakukan:

- Meninjau hasil Intelligence Gathering.
- Mengidentifikasi fitur yang menangani data sensitif atau transaksi (mis. login, pembayaran, endpoint API).
- Menilai tingkat risiko/prioritas tiap fitur.

Contoh Penerapan: dari hasil Intelligence Gathering ditemukan halaman `/login`, `/checkout`, dan `/api/profile` — ketiganya ditandai prioritas Tinggi karena menangani kredensial, transaksi, dan data pribadi. Halaman `/about` atau `/contact` ditandai prioritas Rendah karena murni informatif, tidak memproses input sensitif.

Hasil yang Didapat: Daftar aset/fitur terprioritas beserta alasan dan tingkat risikonya.

Kaitan dengan Dokumen Perencanaan: Mengisi Bagian 3 — tabel Fitur/Aset, Alasan Prioritas, dan Prioritas (Tinggi/Sedang/Rendah).

3.7.4 Vulnerability Analysis

Fase ini terdiri dari dua aktivitas berurutan — Scanning lalu Assessment — sesuai indikator RPS: “vulnerability scanning, false positive, pemetaan CVE/CWE”.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

Apa yang Dilakukan (Scanning):

- Automated scanning penuh (NMAP, OpenVAS, Nessus).
- Active Scan berbasis HTTP (Burp Suite Scanner/OWASP ZAP Active Scan) — boleh dijalankan di target nyata.
- Manual testing per test case WSTG untuk kategori yang ditargetkan.

Contoh Percobaan (Scanning): menjalankan Burp Suite Active Scan pada halaman pencarian produk (mis. `/search?q=`); scanner menandai indikasi SQL Injection dan Reflected XSS pada parameter `q`.

Apa yang Dilakukan (Assessment):

- Memverifikasi setiap temuan scanner secara manual — tidak langsung dipercaya begitu saja.
- Menyaring false positive.
- Memetakan temuan yang terkonfirmasi ke referensi CVE/CWE bila relevan.

Contoh Percobaan (Assessment): memverifikasi manual indikasi SQL Injection dengan mencoba input `test'` pada parameter yang sama dan mengamati apakah muncul pesan error database. Jika ya, kemungkinan besar valid (bukan false positive) — dicatat sebagai kandidat kerentanan dengan referensi CWE-89 (SQL Injection).

Hasil yang Didapat: Daftar kerentanan yang sudah TERKONFIRMASI (bukan mentah dari scanner) — siap dieksploitasi pada fase berikutnya.

Kaitan dengan Dokumen Perencanaan: Mengisi Bagian 4.1 (Scanning) — kategori WSTG, metode scanning, tools — dan Bagian 4.2 (Assessment) — tabel verifikasi temuan dengan status Confirmed/False Positive dan referensi CVE/CWE.

3.7.5 Exploitation

Mencoba mengeksploitasi kerentanan yang sudah terkonfirmasi untuk membuktikan dampak nyata — bukan sekadar potensi di atas kertas.

Apa yang Dilakukan:

- Mencoba teknik/payload spesifik sesuai jenis kerentanan (mis. `sqlmap` untuk SQL Injection, payload XSS, parameter tampering untuk IDOR, dan eksploitasi lain).
- Menghentikan aktivitas begitu menyentuh batas RoE — lihat Kriteria **BERHENTI** yang wajib dicantumkan.

Contoh Percobaan (per Jenis Kerentanan):

- **SQL Injection:** `sqlmap -u "https://<domain>/search?q=test" --batch --dbs` — memetakan nama database yang bisa diakses, tanpa mengekstrak isinya.
- **XSS:** mengirim payload `<script>alert(document.cookie)</script>` pada kolom komentar/pencarian, mengonfirmasi payload benar-benar tereksekusi di browser.
- **IDOR:** mengubah parameter `?order_id=1023` menjadi `?order_id=1024` pada request yang sudah login, mengecek apakah data milik pengguna lain ikut terbuka.

Ketiganya berhenti pada tahap pembuktian dampak — tidak melanjutkan ke ekstraksi data penuh atau perubahan data, sesuai Kriteria Berhenti.

Hasil yang Didapat: Bukti konkret dampak kerentanan (mis. tangkapan layar data yang berhasil diekstrak, bukti bypass autentikasi).

Kaitan dengan Dokumen Perencanaan: Mengisi Bagian 5 — tabel serangan/teknik yang direncanakan per kategori, tools eksploitasi, kriteria validasi temuan, dan kriteria berhenti (begitu command injection atau kerentanan lain memberi akses tingkat sistem operasi/server, aktivitas dihentikan dan dilaporkan sesuai prosedur eskalasi RoE).



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

3.7.6 Post-Exploitation

Menilai dampak bisnis dari akses/data yang berhasil diperoleh, tanpa melangkah lebih jauh dari yang diizinkan.

Apa yang Dilakukan:

- Menganalisis jenis data yang berpotensi terekspos akibat kerentanan yang berhasil dieksploitasi.
- Menilai dampak bisnis jika kerentanan ini dieksploitasi pihak luar yang berniat jahat.

Contoh Penilaian Dampak: setelah SQL Injection berhasil memetakan struktur tabel *users* (tanpa mengekstrak seluruh isinya), dianalisis bahwa tabel tersebut kemungkinan menyimpan kolom email dan *password_hash* — dampaknya: jika dieksploitasi pihak luar yang berniat jahat, seluruh akun pengguna berisiko diambil alih.

Hasil yang Didapat: Narasi dampak/risiko yang akan menjadi bagian dari laporan akhir.

Kaitan dengan Dokumen Perencanaan: Mengisi Bagian 6 — cara menilai dampak temuan. Penilaian dilakukan melalui analisis, bukan dengan melakukan aktivitas lanjutan yang melampaui exclusion list RoE (mis. lateral movement, akses ke sistem lain).

3.7.7 Reporting

Mendokumentasikan seluruh proses dan temuan menjadi laporan yang bisa dipahami dan ditindaklanjuti oleh tim pengembang. Dikerjakan penuh mendekati Pertemuan 15.

Apa yang Dilakukan (mendekati Pertemuan 15):

- Menyusun ringkasan eksekutif, metodologi, temuan per kategori WSTG, dan rekomendasi mitigasi.

Contoh Entri Temuan dalam Laporan:

- **Judul:** *SQL Injection pada Parameter Pencarian Produk*
- **Deskripsi:** parameter *q* pada endpoint */search* tidak memfilter input, memungkinkan injeksi query SQL.
- **Bukti:** tangkapan layar respons error database dan hasil ekstraksi nama tabel.
- **Tingkat Risiko:** CVSS 8.6 (High).
- **Rekomendasi:** gunakan prepared statement/parameterized query, terapkan input validation di sisi server.

Hasil yang Didapat: Laporan akhir pengujian penetrasi yang lengkap.

Kaitan dengan Dokumen Perencanaan: Pada tahap perencanaan (Pertemuan 4), Bagian 7 belum berisi laporan itu sendiri — baru memuat kriteria keberhasilan pelaporan: struktur yang akan diikuti, dan target jumlah kategori WSTG yang harus tercakup sebelum laporan dianggap lengkap.

4. Rangkuman

- RoE dan dokumen perencanaan saling melengkapi: RoE adalah izin, dokumen perencanaan adalah rencana kerja operasionalnya.
- Enam komponen wajib dokumen perencanaan: tujuan, ruang lingkup, target, batasan, jadwal, kriteria keberhasilan.
- Kesesuaian dengan RoE dinilai eksplisit — setiap butir rencana harus bisa dirunut balik ke RoE yang ditandatangani.
- Risiko pengujian pada sistem live sudah dimitigasi lewat desain dua jalur (Real vs Dummy); yang tersisa untuk direncanakan adalah kebersihan data uji dan prosedur pelaporan gangguan.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711

Telepon: (+62766) 24566, Fax: (+62766) 800 1000

Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

-
- PTES adalah kerangka kerja tunggal semester ini; ketujuh fasenya memetakan langsung ke isi dokumen perencanaan, dari Pre-engagement sampai Reporting.
 - Pengujian pada target nyata dikerjakan mandiri oleh setiap mahasiswa.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

5. Tugas Mandiri (Individu)

Terlampir

6. Daftar Pustaka

- The Penetration Testing Execution Standard (PTES). <http://www.pentest-standard.org>
- OWASP Foundation. (2020). OWASP Web Security Testing Guide (WSTG) v4.2.
- Scarfone, K., dkk. (2008). NIST SP 800-115: Technical Guide to Information Security Testing and Assessment. NIST. (Rujukan pembanding, bukan format kerja mata kuliah ini.)
- Dokumen RoE yang telah disusun dan ditandatangani pada Pertemuan 2 (rujukan wajib, bukan pustaka umum).



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

LAMPIRAN

DOKUMEN PERENCANAAN PENGUJIAN PENETRASI

(Penetration Testing Plan — Berbasis Kerangka PTES)

Mata Kuliah Penetration Testing — Prodi Sarjana Terapan Keamanan Sistem Informasi, Politeknik Negeri Bengkalis

Catatan pemakaian: dokumen ini adalah TEMPLATE UMUM yang mengikuti tujuh fase PTES (Penetration Testing Execution Standard) — dapat dipakai untuk proyek pentest mana pun, tidak terbatas pada satu target. Untuk mata kuliah ini, dokumen diisi **secara individu** oleh setiap mahasiswa untuk objek pengujian nyata masing-masing, dan wajib konsisten dengan RoE yang sudah ditandatangani. Semua teks dalam *[tanda kurung siku]* wajib diisi.

Nama Mahasiswa	<i>[nama lengkap]</i>
NIM	<i>[NIM]</i>
Target Pengujian	<i>[nama aplikasi/website] — [URL]</i>
Rujukan RoE	<i>[nomor/tanggal RoE yang mendasari dokumen ini]</i>
Tanggal Penyusunan	<i>[tanggal]</i>
Kerangka Kerja	PTES (Penetration Testing Execution Standard) — 7 fase

1. Pre-engagement Interactions

Fase ini disesuaikan dengan dokumen RoE yang sudah ditandatangani. Jangan menuliskan ulang dari sumber lain atau tambahan yang tidak sesuai RoE.

Tujuan Pengujian	<i>[sesuaikan tujuan]</i>
Ruang Lingkup	<i>[kutip dari RoE Bagian 4 — lapisan & kategori yang tercakup]</i>
Batasan (Exclusion)	<i>[kutip dari RoE Bagian 5]</i>
Jadwal Keseluruhan	<i>[kutip dari RoE Bagian 8]</i>
Kontak Eskalasi	<i>[kutip dari RoE Bagian 6]</i>

2. Intelligence Gathering

Karena RoE membatasi pengujian pada lapisan aplikasi, seluruh teknik di fase ini bersifat pasif/berbasis HTTP publik — tidak menyentuh port di luar 80/443.



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

Teknik yang direncanakan:

- ☐ WHOIS / pencarian registrasi domain
- ☐ DNS lookup (dig/nslookup)
- ☐ Google dorking
- ☐ Pemeriksaan header HTTP (curl -I / curl -v)
- ☐ Deteksi teknologi (WhatWeb / Wappalyzer)
- ☐ Lainnya: *[sebutkan]*

Sumber informasi yang ditargetkan:

[mis. subdomain, teknologi yang dipakai, informasi kontak publik]

Estimasi waktu: *[jumlah jam/hari]*

3. Threat Modeling

Identifikasi fitur/aset aplikasi yang paling bernilai atau paling berisiko, untuk diprioritaskan pengujiannya.

Fitur/Aset	Alasan Prioritas	Prioritas
<i>[mis. form login]</i>	<i>[mengapa fitur ini penting diuji]</i>	<i>[T/S/R]</i>
<i>[mis. form login]</i>	<i>[mengapa fitur ini penting diuji]</i>	<i>[T/S/R]</i>
<i>[mis. form login]</i>	<i>[mengapa fitur ini penting diuji]</i>	<i>[T/S/R]</i>
<i>[mis. form login]</i>	<i>[mengapa fitur ini penting diuji]</i>	<i>[T/S/R]</i>

Prioritas: T = Tinggi, S = Sedang, R = Rendah.

4. Vulnerability Analysis

Fase ini terdiri dari dua aktivitas berurutan: Scanning (menemukan kandidat kerentanan) dan Assessment/Verifikasi (menyaring false positive, memetakan ke CVE/CWE). Keduanya wajib diisi terpisah.

4.1 Scanning

Kategori OWASP WSTG yang ditargetkan:

- ☐ Information Gathering
- ☐ Configuration and Deployment Management Testing
- ☐ Identity Management Testing
- ☐ Authentication Testing
- ☐ Authorization Testing
- ☐ Session Management Testing
- ☐ Input Validation Testing (SQL Injection, XSS, dsb.)
- ☐ Error Handling & Cryptography
- ☐ Business Logic Testing
- ☐ Client-Side Testing

Metode scanning yang dipakai:



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

- ☐ Automated scanning penuh (OpenVAS/Nessus)
- ☐ Active Scan berbasis HTTP (Burp Suite Scanner / OWASP ZAP Active Scan)
- ☐ Manual testing per test case WSTG (tanpa tools otomatis)

Tools yang dipakai: *[mis. Burp Suite, OWASP ZAP]*

Tools yang TIDAK dipakai (peringat batasan RoE): Nmap, Nessus/OpenVAS terhadap target nyata, dan seluruh tools pemindai jaringan/infrastruktur.

4.2 Assessment (Verifikasi Temuan)

Setiap temuan dari scanning — khususnya dari automated scanning — wajib diverifikasi secara manual sebelum dianggap sebagai kerentanan yang sah. Tujuannya menyaring false positive dan memetakan temuan ke referensi CVE/CWE bila relevan.

Temuan Scanner	Kategori WSTG	Verifikasi Manual	CVE/CWE (jika ada)
<i>[nama/deskripsi temuan]</i>	<i>[kategori]</i>	<i>[Confirmed / False Positive]</i>	<i>[mis. CWE-89]</i>
<i>[nama/deskripsi temuan]</i>	<i>[kategori]</i>	<i>[Confirmed / False Positive]</i>	<i>[mis. CWE-89]</i>
<i>[nama/deskripsi temuan]</i>	<i>[kategori]</i>	<i>[Confirmed / False Positive]</i>	<i>[mis. CWE-89]</i>

Baris di atas diisi setelah scanning benar-benar dijalankan — pada tahap perencanaan ini, cukup pastikan format tabel sudah dipahami.

5. Exploitation

Serangan/teknik eksploitasi yang direncanakan, per kategori kerentanan yang dikonfirmasi pada Bagian 4:

Kategori Kerentanan	Teknik/Payload Contoh	Tools
SQL Injection	<i>[UNION-based / boolean-based blind pada parameter id atau search]</i>	sqlmap, Burp Repeater
Cross-Site Scripting (XSS)	<i>[Reflected XSS via parameter pencarian, payload <script>alert(document.cookie)</script>]</i>	Burp Suite, payload manual
Broken Authentication	<i>[Uji daftar kredensial umum pada form login secara terbatas (rate-limited, bukan brute force penuh)]</i>	Burp Intruder (terbatas), pengujian manual
Broken Access Control / IDOR	<i>[Ubah parameter id (mis. user_id, order_id) pada URL/request untuk mengakses data akun lain]</i>	Burp Suite Repeater, parameter tampering manual
Session Management	<i>[Uji apakah token sesi tetap valid setelah]</i>	Burp Suite



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS, DAN TEKNOLOGI

POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

	<i>logout, atau apakah token dapat ditebak/diprediksi]</i>	(cookie/token inspection)
Business Logic	<i>[Manipulasi nilai kuantitas/harga saat checkout (mis. kuantitas negatif) untuk menguji validasi sisi server]</i>	Burp Suite Repeater, pengujian manual
<i>[kategori temuan Anda sendiri]</i>	<i>[teknik/payload]</i>	<i>[tools]</i>
<i>[kategori temuan Anda sendiri]</i>	<i>[teknik/payload]</i>	<i>[tools]</i>

Tools eksploitasi yang dipakai:

- ☐ sqlmap (validasi & eksploitasi SQL Injection)
- ☐ Burp Suite Intruder/Repeater (payload manual & terautomasi)
- ☐ OWASP ZAP (manual attack mode)
- ☐ Payload/skrip kustom (mis. XSS payload, IDOR parameter tampering)
- ☐ Lainnya: *[sebutkan]*

Tools yang TIDAK dipakai (peringat batasan RoE): Metasploit modul jaringan/OS, exploit biner/binary payload, dan seluruh tools yang menasar lapisan sistem operasi/server, bukan aplikasi.

Kriteria temuan dianggap tervalidasi: *[mis. berhasil mengeksekusi payload dan mengonfirmasi dampaknya]*

Kriteria BERHENTI (wajib, tidak dapat diubah): Begitu suatu command injection atau kerentanan lain terbukti memberi akses tingkat sistem operasi/server, aktivitas pada temuan tersebut DIHENTIKAN dan segera dilaporkan sesuai prosedur eskalasi RoE — tidak dieksplorasi lebih lanjut.

6. Post-Exploitation

Cara menilai dampak temuan: *[mis. jenis data yang berpotensi terekspos, dampak bisnis jika dieksploitasi pihak luar]*

Penilaian dampak dilakukan melalui analisis, bukan dengan melakukan aktivitas lanjutan yang melampaui exclusion list RoE (mis. lateral movement, akses ke sistem lain).

7. Reporting

Struktur laporan akhir yang akan diikuti:

- Ringkasan Eksekutif
- Metodologi (rujuk kerangka PTES ini)
- Temuan per kategori WSTG, lengkap dengan tingkat risiko (CVSS) dan bukti
- Rekomendasi mitigasi

Kriteria keberhasilan pelaporan: *[mis. seluruh kategori WSTG yang ditargetkan pada Bagian 4 telah diuji dan dilaporkan, terlepas dari jumlah temuan]*



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

8. Rencana Kerja Mingguan

Isi tabel berikut untuk memetakan aktivitas per minggu, termasuk lingkungan yang dipakai (Real/Dummy) sesuai batasan RoE.

Mg	Fase PTES	Aktivitas	Lingkungan
5	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
6	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
7	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
9	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
10–12	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
13	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
14	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]
15	[mis. Intelligence Gathering]	[aktivitas konkret]	[Real]

9. Persetujuan

Dengan menandatangani dokumen ini, dosen pengampu menyatakan telah memverifikasi kesesuaian rencana ini dengan RoE yang berlaku (**Lampirkan RoE yang sudah diperbaiki dan ditandatangani**).

Mahasiswa

Dosen Pengampu

(_____)

(_____)

Nama:

Nurmi Hidayasari

Tanggal:

Tanggal:

Catatan:



KEMENTERIAN PENDIDIKAN, TINGGI, SAINS,
DAN TEKNOLOGI
POLITEKNIK NEGERI BENGKALIS

Jalan Bathin Alam, Sungai Alam, Bengkalis, Riau 28711
Telepon: (+62766) 24566, Fax: (+62766) 800 1000
Laman: <http://www.polbeng.ac.id>, E-mail: polbeng@polbeng.ac.id

Tandatangan dosen pada dokumen RoE dan perencanaan dikosongkan terlebih dahulu.